# #2
# Securing Enterprise Networks

Kasun Chathuranga

ICT 3216 - Introduction to Ethical Hacking | Rajarata University of Sri Lanka

# Quick Recap: Networking Essentials

**Private IP Address Ranges:**

Private IP addresses are non-routable on the public internet and are used within internal networks. These are defined in three blocks by the Internet Assigned Numbers Authority (IANA).

- ***Class A (10.0.0.0 - 10.255.255.255):***

  Large networks, allowing for over 16 million addresses.

- ***Class B (172.16.0.0 - 172.31.255.255):***

  Medium-sized networks, allowing for over 1 million addresses.

- ***Class C (192.168.0.0 - 192.168.255.255):***

  Smaller networks, typically used for home or small business environments, allowing for 65,536 addresses.

# Quick Recap: Networking Essentials

**Port Ranges & Common Ports**

Network communication happens through ports, which are virtual points where network connections start and end. There are three ranges of ports:

- ***Well-known Ports (0-1023):***
  - Common services and protocols operate here.
  - Examples: HTTP (Port 80), HTTPS (Port 443), FTP (Port 21), SSH (Port 22)

- ***Registered Ports (1024-49151):***
  - Used by vendors for proprietary services and protocols.
  - Examples: MySQL (Port 3306), Microsoft SQL Server (Port 1433)

- ***Dynamic/Private Ports (49152-65535):***
  - Used for temporary or private purposes, mainly during client-server communication (e.g., ephemeral ports for outbound connections).

# Pandora Company - Applied Network Learning

Pandora Company operates a network where all devices and servers are connected within the same network (192.168.1.1). The setup includes:

- **25 Employee Computers:**
  - All employees (including system admins) access the company's systems using computers on the same network.
- **Web Server:**
  - A Linux-based server that hosts the company's website, which is available to the public.
- **Application Server (E-shop: Pandora):**
  - The e-shop, Pandora, is accessible through both a web application and a mobile app (REST API), allowing customers to browse products, make purchases, and manage accounts.
  - Employees also use the same server for admin tasks like managing orders and inventory.
- **MySQL Database Server:**
  - Stores customer information, order details, and product inventory. Both the e-shop and internal employees rely on this server for data.

# Task:
# Improve the security posture of Pandora Company

# Risks

# Case 1: Web Server Got Hacked

- **Description:**
  - An attacker successfully compromises Pandora’s web server, gaining access to the internal network. This exposes critical internal systems due to the flat network setup.
- **Key Risks:**
  - **Lateral movement:** Since the web server is on the same network as the application and database servers, the attacker can easily explore and attack other systems.
  - **Data breach:** The attacker can access sensitive customer data stored in the MySQL database by moving from the web server to the internal servers.
  - **Service disruption:** The e-shop could be taken offline, resulting in loss of revenue and customer trust.

# Case 2: User Computer Infected by Malware (RAT)

- **Description:**
  - One of Pandora's employee computers is infected with malware, specifically a Remote Access Trojan (RAT), allowing an attacker to control the computer remotely.

- **Key Risks:**
  - **Access to internal resources:** The compromised computer can interact with the application server, database, and other employee computers, leading to data theft or system manipulation.
  - **Privilege escalation:** The attacker can leverage the infected computer to steal credentials and escalate privileges, gaining wider access to internal resources.
  - **Spread of malware:** The malware can propagate to other employee computers and servers, leading to widespread damage.

# Case 3: Rogue Employee

- **Description:**
  - An internal employee with access to the application and database servers intentionally misuses their privileges to steal customer data or disrupt operations.

- **Key Risks:**
  - **Insider threat:** The employee could alter or delete data, or exfiltrate sensitive information such as customer details and financial records.
  - **System compromise:** The rogue employee may install backdoors or sabotage systems, leading to service outages and potential long-term damage.
  - **Difficulty detecting:** Without proper monitoring and controls, detecting and preventing the misuse of legitimate credentials can be challenging.

# Firewalling

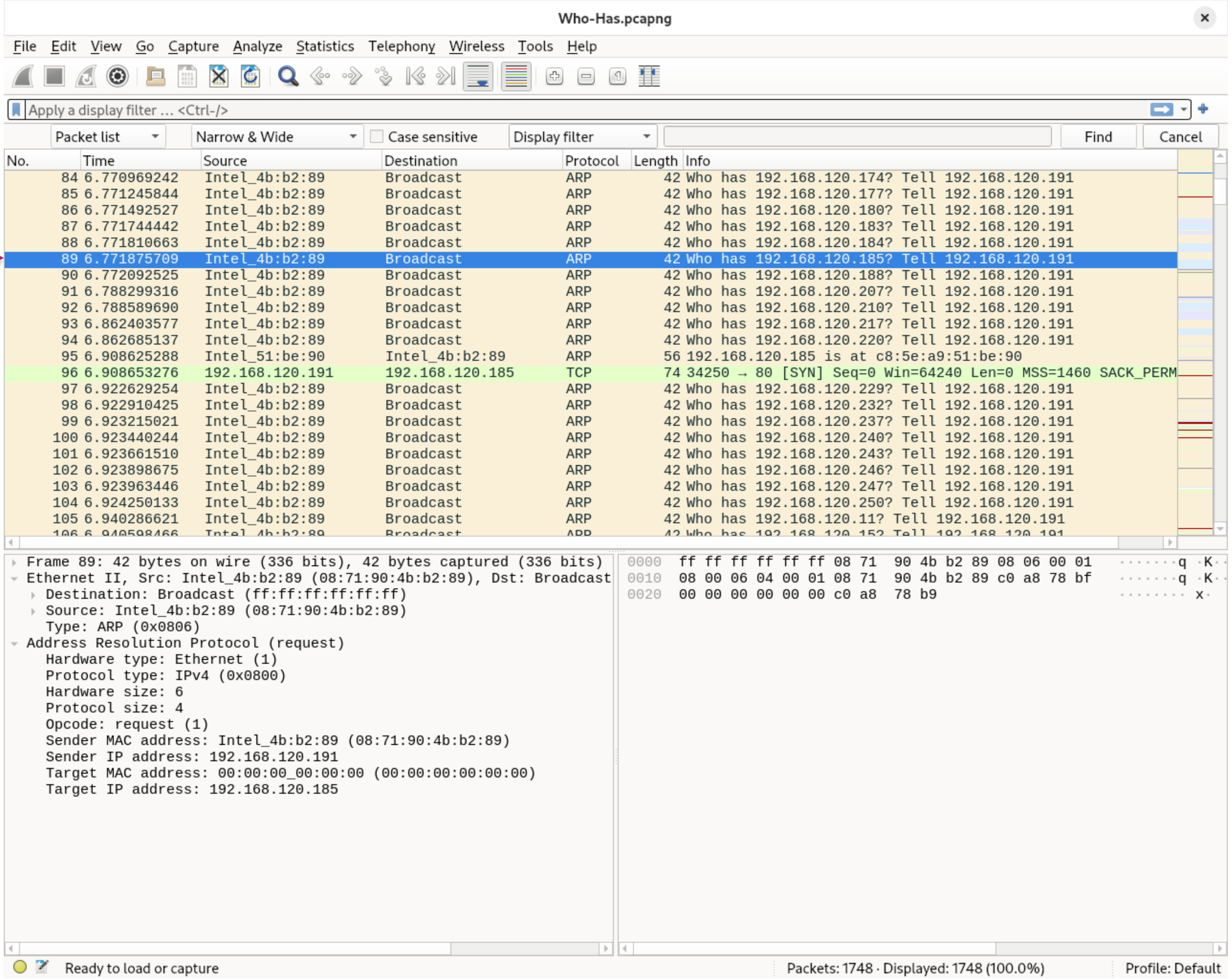
# What Happens Below Layer 3

**ARP (Address Resolution Protocol)**

- What is ARP?
  - ARP is responsible for mapping an IP address (Layer 3) to a physical MAC address (Layer 2).
  - When a device needs to communicate with another on the same network, it sends an ARP request: "Who has this IP?"
  - The target device responds with an ARP reply, providing its MAC address.

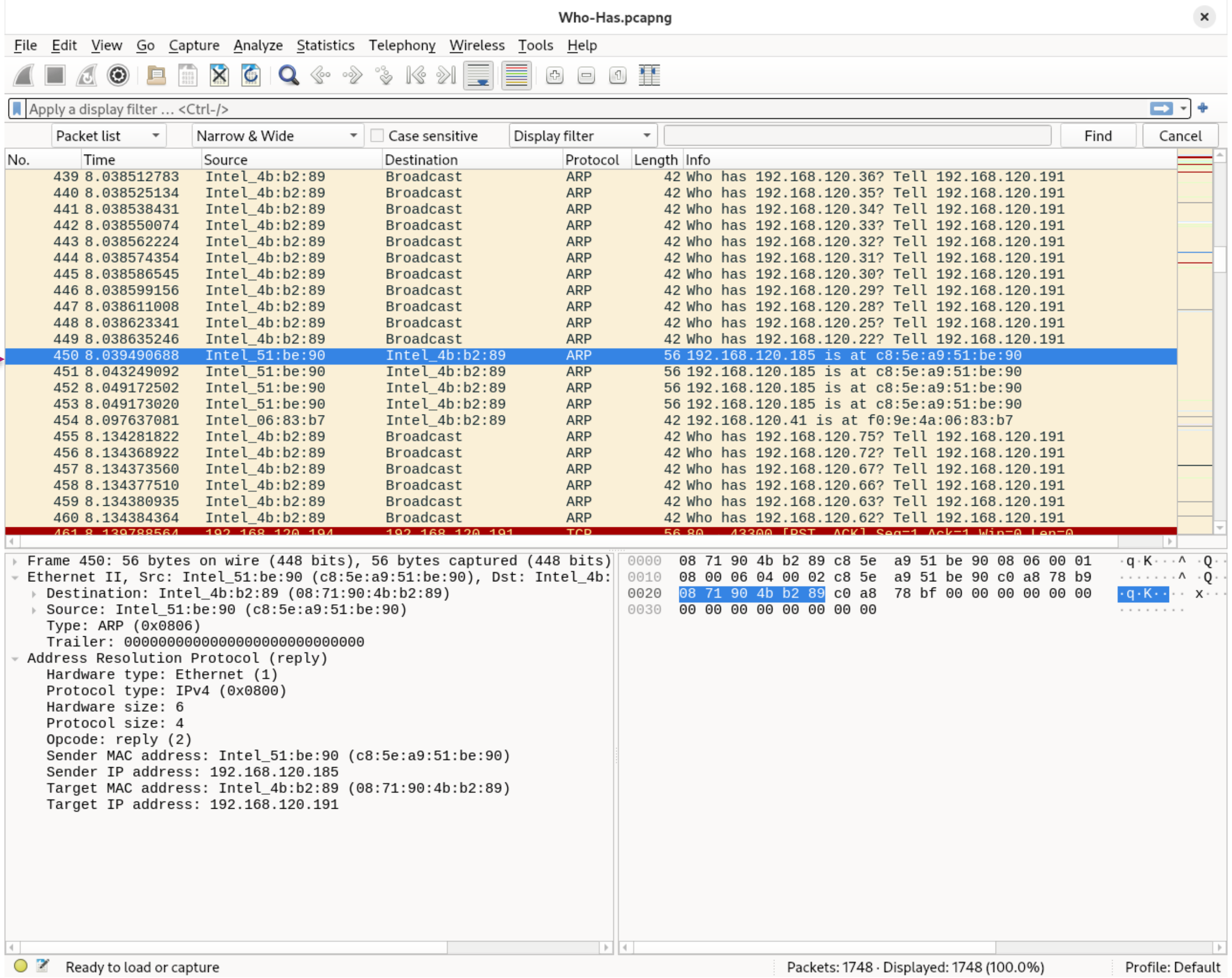
# ARP Request

ARP request: "Who has 192.168.120.185?



# ARP Reply

ARP reply: "192.168.120.185 is at MAC address *00:1a:2b:3c:4d:5e*



# Frame Transmission

Once the sender has the recipient's MAC address, it creates an Ethernet frame. Once the frame is created, it is sent to the physical layer (Layer 1) for transmission over the network.

- **Delivery to the Local Network:**
  - The Ethernet frame is broadcast on the local network or delivered directly to a specific device if it's connected via a switch.
  - Switches maintain a MAC address table, mapping each MAC address to the corresponding switch port.
  - When the Ethernet frame arrives, the switch checks the destination MAC address against its MAC address table and forwards the frame to the correct port.
- **Beyond the Local Network**
  - If the destination is on a different network (i.e., beyond the local LAN), the Ethernet frame is sent to the default gateway (usually a router), which forwards it to the destination network.

# To Take the Control

- **Firewall:**

To control traffic between network segments and protect internal systems from unauthorized access. A firewall ensures that only necessary and authorized communication happens between network zones (e.g., between the web server, application server, and database).

**And**

- **Option A – With Multiple Switches:**

To physically separate network traffic between employee computers, servers, and other critical resources.

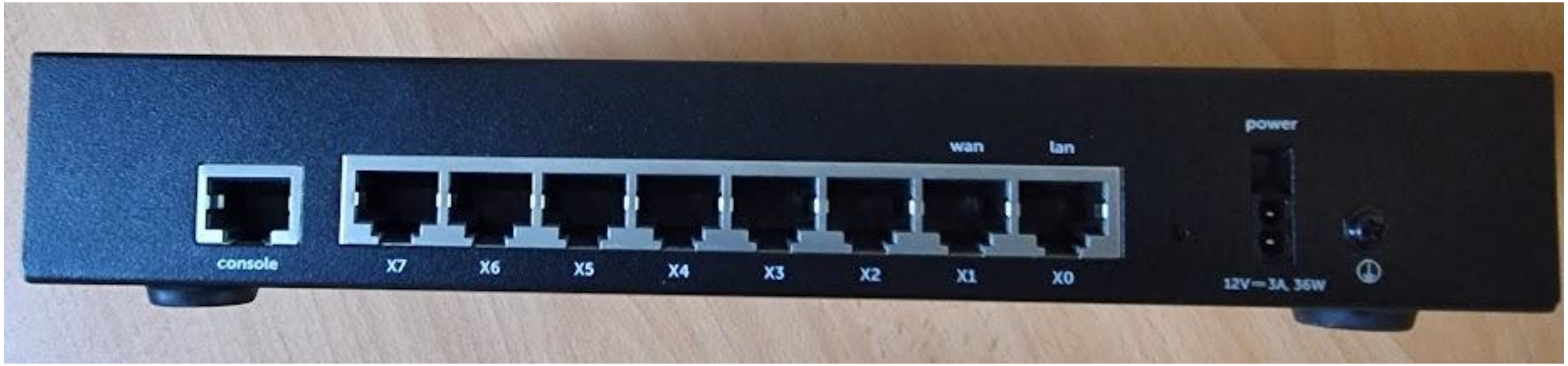
- **Option B – With VLAN-Supported Switch:**

To logically separate network traffic between employee computers, servers, and other critical resources. A VLAN switch enables the creation of separate virtual networks, isolating sensitive data and reducing security risks.

# Example Firewall

### Front


### Back



# Firewall

- **What is a Firewall?**
  - A Firewall protects internal networks by controlling and filtering traffic between trusted and untrusted networks, based on predefined security rules.
- **Key Features:**
  - ***Traffic Filtering***: Controls traffic based on IP addresses, protocols, ports, and applications to block unauthorized access.
  - ***Stateful Inspection***: Tracks active connections to ensure only legitimate traffic is allowed.
  - ***Intrusion Detection/Prevention (IDS/IPS):*** Detects and prevents malicious activity within network traffic (optional feature in advanced firewalls).
  - ***VPN Support:*** Secures remote access to internal networks via Virtual Private Networks (VPNs).
  - ***Logging & Monitoring:*** Provides detailed logs and real-time monitoring of traffic to identify & respond to threats.
  - ***Application Control:*** Filters traffic based on application-specific rules (e.g., allowing/blocking certain apps or services).
- **Firewall Options**:
  - Solutions from Cisco, Fortinet, Palo Alto, & Check Point offer robust hardware firewalls with advanced security features.
  - Firewalls are also available as cloud-based services (e.g., AWS Firewall, Azure Firewall) or deployed as virtual firewalls within virtual machine infrastructure.

# Proposed Network Segments

- **DMZ (Demilitarized Zone):**
  - **Purpose:** Hosts the public-facing web server and reverse proxy with WAF module (new server addition current network), isolating external traffic from internal resources.
  - **Key Role:** Allows external access to the e-shop without exposing the internal application and database servers.

- **High-Security Zone:**
  - **Purpose:** Contains critical servers such as the application server and database.
  - **Key Role:** Only essential services and systems can communicate with this zone, ensuring strong protection of sensitive data.

# Proposed Network Segments

- **User LAN:**
  - **Purpose:** Provides access for employee computers to the admin side of the application.
  - **Key Role:** Employees can access the admin panel while remaining isolated from critical servers.

- **Management LAN:**
  - **Purpose:** Dedicated for IT staff to securely manage and monitor all systems.
  - **Key Role:** Used for administrative tasks like remote access (SSH, RDP) to critical infrastructure, ensuring separation from the user network.

# Access Control Matrix for Pandora Network Segments

| | Source | Destination | Port(s) | Allowed Access |
|---|---|---|---|---|
| #1 | External Clients | Web Server (DMZ) | 443 (HTTPS) | Web traffic (Website access) |
| #2 | External Clients | Reverse Proxy (DMZ) | 443 (HTTPS) | Web traffic (e-shop access) |
| #3 | App Server (High-Security) | Database (High-Security) | 3306 (MySQL) | Database queries from the app |
| #4 | Employee Computers (User LAN) | App Server (High-Security) | 443 (HTTPS) | E-shop Admin access to app (via HTTPS) |
| #5 | Management LAN | All Servers (DMZ, High-Security) | 22 (SSH), 3389 (RDP) | Administrative management (SSH, RDP) |

# Isolation & Routing

- VLANs are configured for each zone: DMZ, High-Security Zone, User LAN, and Management LAN.
- Inter-VLAN routing is done by the firewall, ensuring that communication between zones only happens over approved ports and under strict security controls.
- Micro-segmentation can be applied within each VLAN to further restrict traffic between individual devices or services, reducing the attack surface even within the same zone.

# Monitoring, Alerting, and Logging for Enhanced Security

1. **Real-time Monitoring:**
   - **Continuous Traffic Analysis:** Inspects all network traffic, detecting anomalies and threats in real-time.
   - **Threat Detection:** Identifies suspicious behavior like unauthorized access or policy violations.

2. **Alerts:**
   - **Customizable Alerts:** Generates real-time alerts for security events (e.g., failed logins, breaches).
   - **Automated Response:** Triggers immediate actions (e.g., blocking malicious IPs or isolating devices).

3. **Detailed Logging:**
   - **Comprehensive Logs:** Captures all network activities for auditing, compliance, and incident investigations.
   - **Incident Analysis:** Provides crucial data for tracing attacks and understanding security incidents.

# Web Application Firewall (WAF)

- **What is a WAF?**
  - A Web Application Firewall (WAF) protects web applications by filtering and blocking HTTP/HTTPS traffic to and from the web app, preventing common attacks like SQL injection, XSS, and DDoS.

- **Deployment Options:**
  - ***Appliances:*** Hardware-based solutions like F5 and Imperva.
  - ***Cloud WAF:*** Providers like Cloudflare, Akamai, Sucuri, and Huawei offer scalable cloud-based WAFs.
  - ***Plugins:*** Web server plugins like mod_security can be used in reverse proxy setups.

- **Why It's Important:**
  - ***Layered Security:*** Adds another layer on top of traditional firewalls, focusing on application-specific threats.
  - ***Real-Time Protection:*** Blocks malicious traffic in real-time, reducing the attack surface.
  - ***Customizable:*** Allows for tailored security rules specific to your web application.

# Mini Challenge

25 individual Windows PCs operate across various departments. Each PC has its setup, resulting in a lack of uniformity concerning user policies, software installations, and security configurations. Observations include employees using unsafe passwords like "1234", challenges in deploying updates uniformly across all computers, and inconsistent access restrictions.

# Solution: Centralized Management with Active Directory (AD)

- **Use Active Directory (AD):** On-Premises AD or Cloud-Based Azure AD: Deploying either on-prem AD or cloud-based Azure AD can centralize user management, security policies, and device configurations.

- **Key Benefits:**
  - Uniform User Policies: Enforce strong password policies (e.g., banning weak passwords like "1234").
  - Apply consistent access controls across all user accounts and devices.
  - Use Conditional Access to enforce multi-factor authentication (MFA) and device compliance checks.
  - Implement Single Sign-On (SSO) for employees using Microsoft 365 services, ensuring secure, centralized access.
  - Microsoft Endpoint Manager: For cloud setups, manage devices and apps using Microsoft Endpoint Manager (formerly known as Intune) to ensure compliance and security.

# Questions?